

CURDUN ERP

Backend Architecture & REST API Documentation

COR Platform - CURDUN ICT Solutions

Version: 1.0.0 (Pure Custom PHP 8 MVC)

Database: curdun_erp (MySQL 8 - 34 Tables)

Date: August 2026

1. Executive Summary & Architecture

The Curdun ERP backend is a 100% backend-only REST API system built for CURDUN ICT Solutions. It employs a custom pure PHP 8+ MVC architecture without external frameworks (such as Laravel or Symfony). The architecture strictly adheres to modern OOP principles, PSR-4 autoloading, PDO prepared statements, and clean separation of concerns across Controllers, Services, Repositories, and Models.

Key Architectural Constraints:

- 100% BACKEND ONLY: Zero HTML/CSS/JS frontend dependencies.
- Pure PHP 8+ & MySQL 8+: Utilizes native PDO with prepared statements for all database access.
- Thin Controllers & Layered Design: Request -> Controller -> Service -> Repository -> Model -> Database.
- RBAC Security: Strict Role-Based Access Control enforcing fine-grained module permissions.
- Database Concurrency Safety: Uses SELECT ... FOR UPDATE row-locking during inventory transactions.
- Standardized JSON Responses: Every endpoint outputs uniform JSON structure across success and error paths.

Directory Structure:

```
backend/
|-- app/
|   |-- Controllers/      (25 Thin API Controllers)
|   |-- Models/          (31 Entity Models extending BaseModel)
|   |-- Services/         (25 Business Logic Services)
|   |-- Repositories/     (23 Repositories for Database Abstraction)
|   +-- Middleware/       (AuthMiddleware, RoleMiddleware, PermissionMiddleware)
|-- config/               (app.php, database.php, security.php, cors.php, constants.php)
|-- core/                 (Database, Router, Request, Response, Auth, Session, Validator, Logger)
|-- exceptions/           (Validation, Authentication, Authorization, NotFound, Conflict)
|-- helpers/              (response.php, validation.php, security.php, formatting.php, permissions.php)
|-- routes/               (api.php - REST API v1, web.php)
|-- database/             (curdun_erp.sql - 34 Tables, seed.php importer)
+-- public/               (index.php Single Entry Point, .htaccess)
```

2. Database Schema & Relational Structure

The 'curdun_erp' MySQL database consists of 34 relational tables organized into 8 functional domain modules:

Module	Database Tables
Auth & ACL	users, roles, permissions, user_roles, role_permissions, sessions, password_resets
Organization	companies, branches, departments
CRM	customers, suppliers
Inventory	categories, units, taxes, warehouses, products, stock_movements
Purchases	purchase_orders, purchase_order_items
Sales	orders, order_items, sales_returns, sales_return_items
Finance	invoices, invoice_items, payments, payment_methods, expenses, expense_categories, currencies
System	notifications, settings, audit_logs

Default Admin Credentials:

- Username/Email: admin@curdun.so
- Password: Admin@1234
- Default Role: superadmin

3. Complete REST API Endpoints Reference

Method	Route Endpoint	Description	Permission
POST	/api/v1/auth/login	Authenticate user & start session	Public
POST	/api/v1/auth/logout	Terminate active user session	Authenticated
GET	/api/v1/auth/me	Get current user profile & roles	Authenticated
POST	/api/v1/auth/forgot-password	Generate password reset token	Public
POST	/api/v1/auth/reset-password	Execute password reset with token	Public
GET	/api/v1/users	Paginated list of users	users.view
POST	/api/v1/users	Create user account	users.create
GET	/api/v1/users/{id}	Get single user details	users.view
PUT	/api/v1/users/{id}	Update user account	users.update
DELETE	/api/v1/users/{id}	Soft-delete user account	users.delete
POST	/api/v1/users/{id}/roles	Assign user roles	roles.update
GET	/api/v1/roles	List all system roles	roles.view
POST	/api/v1/roles	Create new role with permissions	roles.create
GET	/api/v1/permissions	List permissions grouped by module	roles.view
GET/POST	/api/v1/customers	Customer management & search	customers.*
GET/POST	/api/v1/suppliers	Supplier management & search	suppliers.*
GET/POST	/api/v1/products	Product management & barcode lookup	products.*
GET	/api/v1/products/low-stock	List low stock alert items	products.view
GET/POST	/api/v1/inventory	Stock levels & movement history	inventory.*
POST	/api/v1/inventory/adjust	Manual stock quantity adjustment	inventory.adjust
POST	/api/v1/inventory/transfer	Inter-warehouse stock transfer	inventory.adjust
GET/POST	/api/v1/orders	Sales order processing	orders.*
POST	/api/v1/orders/{id}/complete	Execute order completion workflow	orders.complete
GET/POST	/api/v1/invoices	Invoice creation & management	invoices.*
POST	/api/v1/payments	Record customer payments	payments.create
GET/POST	/api/v1/expenses	Track company business expenses	expenses.*
GET	/api/v1/reports/sales	Generate detailed sales reports	reports.view
GET	/api/v1/reports/revenue	Generate revenue reports	reports.view
GET	/api/v1/dashboard/summary	Dashboard overall metrics summary	Authenticated
GET	/api/v1/audit-logs	System audit trails & operation logs	audit_logs.view

4. Business Logic Workflows & Security

Order Completion Workflow (POST /api/v1/orders/{id}/complete)

1. Validate Order: Verifies that the order exists and is in CONFIRMED state.
2. Stock Verification & Row Locking: Issues 'SELECT ... FOR UPDATE' on product rows to lock stock during checkout.
3. Inventory Reduction: Reduces product stock quantity safely.
4. Stock Movement Creation: Automatically inserts a 'stock_movements' record of type 'SALE'.
5. Invoice Generation: Creates a new Invoice with subtotal, tax, discount, total, and balance.
6. Audit Logging: Logs the action, acting user ID, IP address, and timestamp.
7. Atomic Commit: All steps complete inside a PDO Transaction block; failure triggers instant ROLLBACK.

Security & Compliance Features:

- SQL Injection Prevention: All DB access uses PDO prepared statements with bound parameters.
- Secure Password Hashing: BCrypt algorithm with cost factor 12 (password_hash).
- Session Hardening: Configured with HttpOnly, SameSite=Strict, session regeneration, and lifetime expiration.
- Rate Limiting: Built-in IP-based rate limiting on sensitive endpoints (e.g., 5 attempts in 5 mins for login).
- HTTP Security Headers: Emits X-Frame-Options, X-Content-Type-Options, CSP, and CORS restrictions.

--- End of Technical Documentation ---